

HW06 — API Testing Report: EShop (SUT)

Sinh viên: Đặng Trường Nguyên

MSSV: 23127438 · Lớp: 23KTPM3

Môn: CS423 / CSC13003 — Software Testing (AI-augmented, 2026)

Ngày: 23/08/2026

Repo: <https://github.com/trngnneee/eshop-sut>

1. Phạm vi & Hệ thống dưới kiểm thử (SUT)

SUT: EShop backend Node.js + Express + SQLite, `http://localhost:3000` . `database.js` **DROP + reseed** toàn bộ mỗi lần `node server.js` ⇒ môi trường sạch: 3 categories (id 1–3), 5 products (id 1–5), bảng `orders` rỗng.

Scope 3 API:

API	Endpoint	FR	Kỹ thuật chính
API-1	<code>GET /api/products/:id (+ GET /api/products?search=)</code>	FR-05 / FR-06	Partition + BVA · Security (SQLi/XSS) · Schema · Negative
API-2	<code>PUT /api/orders/:id/cancel</code>	FR-10	Partition · State-transition · Security (auth/forge/IDOR) · Schema · Negative
API-3	<code>POST /api/products + PUT /api/products/:id</code>	FR-15 / FR-12	Input validation (Partition+BVA) · Auth/escalation · Schema

Tài khoản seed: `admin@eshop.com/Admin123!` (id=1, admin) · `test@eshop.com/Test1234!` (id=2, user).

Nguyên tắc oracle: Expected luôn lấy theo contract (FR/OpenAPI). SUT chạy lệch spec = **bug**; giữ nguyên expected để test FAIL đúng chỗ.

2. Quy trình 5 bước cho mỗi API

- Generate (Bước 2):** AI (Claude Code) sinh test case theo từng kỹ thuật, driven từng nhóm một (không “generate all”). Đầu vào: FR trong README + đoạn source `server.js` / `database.js` + OpenAPI.

2. **Audit (Bước 3):** tôi tự dò từng case (docs/ai-testcase-audit.md), gán VALID/INVALID/INCOMPLETE, gộp trùng (TC-P3-048), sửa expected sai.
3. **Extend (Bước 4):** thêm 7 case AI-sinh-từ-spec để bỏ sót (docs/extended-cases.md) — case phụ thuộc implementation.
4. **Execute:** probe cURL live (backup/restore database.sqlite) → điền cột Actual; sau đó đóng gói Postman + chạy Newman.
5. **Bug report:** map mỗi FAIL → bug, viết theo template Issue, đẩy lên GitHub Issues.

Tổng: 212 case AI sinh → audit (−1 gộp, +1 bù) → +7 extend = 219 case hiệu lực.

3. Thiết kế test & số lượng

API	Partition/ BVA	State	Security	Schema	Negative	Extend	Tổng
API-1	44	—	14	16	9	2	85
API-2	15	9	13	11	9	2	59
API-3	48	—	13	11	—	3	75
							219

Chi tiết TC-ID + bảng partition: testcases/00-TestCases-Summary.md và 12 file testcases/API-*.md .
Contract + hành vi sai (x-sut-actual): openapi.yaml .

4. Kết quả thực thi

Chạy full collection (238 request):

- Postman Collection Runner: 905 tests → 629 pass / 276 fail.
- Newman + htmlextra: 893 assertions → 566 pass / 327 failed (newman/report.html).
- Data-driven (Runner + CSV): newman/report-dd1.html (matrix id chẵn/lẻ), report-dd2.html (matrix validation).

Ở mức **test case**: 219 executed · ≈145 PASS · ≈74 VALID-but-FAIL (lộ bug). Các FAIL là **có chủ đích**, không phải lỗi test.

5. Bug — 20 defect đã verify

FR/Severity + Issue link (đầy đủ: bug-reports/README.md , GitHub Issues #440–#459):

Module	Bug	Severity	Issue
API-1	<code>price</code> trả string với id chẵn (sai kiểu)	Major/P1	#452
API-1	GET id không tồn tại trả <code>200 {}</code> thay vì 404	Major/P1	#450
API-1	Không validate kiểu <code>:id</code> (sai kiểu vẫn <code>200 {}</code>)	Minor/P2	#443
API-1	Lỗi SQL trả HTML + lộ message DB (500 text/html)	Major/P1	#456
API-1	id không canonical được chấp nhận (numeric affinity)	Minor/P2	#444
API-1	Tìm kiếm không nhất quán Unicode (chữ HOA có dấu → 0)	Major/P1	#458
API-1	SQLi / wildcard bypass ở <code>?search=</code> (<code>%,_,tautology</code> → toàn bộ)	Critical/P0	#457
API-1	Param <code>search</code> lặp → 0 kết quả im lặng	Minor/P2	#455
API-1	SQLi UNION lộ email + password plaintext + role admin	Critical/P0	#459
API-1	Thiếu header <code>X-Content-Type-Options: nosniff</code>	Minor/P2	#446
API-1/2/3	Lỗi 404/400 trả HTML thay vì JSON <code>{error}</code>	Minor/P2	#442
API-2	User hủy được đơn <code>shipping</code> (đáng lẽ chỉ Admin)	Critical/P0	#440
API-2	Đọc đơn bất kỳ KHÔNG cần token (IDOR read)	Critical/P0	#451
API-2/3	Secret JWT hardcoded → forge token, mạo danh + nâng quyền	Critical/P0	#445

Module	Bug	Severity	Issue
API-3	CRUD sản phẩm KHÔNG auth — ẩn danh tạo/sửa/XOÁ	Critical/P0	#453
API-3	POST/PUT không validate FR-15 (name/price/category)	Critical/P0	#448
API-3	Body rỗng {} tạo record toàn null	Major/P1	#441
API-3	name > 255 ký tự vẫn được tạo	Major/P1	#447
API-3	PUT thiếu field → null hóa (mất dữ liệu)	Critical/P0	#454
API-3	PUT/DELETE id không tồn tại → 200 no-op thay vì 404	Major/P1	#449

Tổng: Critical/P0 = 8 · Major/P1 = 7 · Minor/P2 = 5. **CỜ SEC-04** (không tính bug API riêng):

name / description / search lưu-trả nguyên văn ⇒ stored/reflected XSS vector nếu FE render không escape — kiểm chéo tầng UI (FR-05). **Bug ngoài scope (1 dòng):** login logout sau 2 lần sai (FR-02), PUT /api/users/me cho set role (SEC-06), OTP reset 4 số không hạn dùng (SEC-07), admin state cho canceled→delivered (FR-10), mật khẩu plaintext (SEC-01).

6. Postman collection & features

postman/EShop-HW06.postman_collection.json (v2.1.0, 7 folder, 238 request). Env EShop-Local . 5 JSON Schema ở collection variables. Pre-request cấp collection tự chèn X-Student-Id . Bảng đầy đủ "feature → ở đâu": postman/POSTMAN-FEATURES.md (17 feature: nested folders, environment, collection vars, pre-request, pm.test, jsonSchema, chaining, dynamic vars, Runner+CSV, Bearer inherit, pm.sendRequest, Mock, examples, Monitor, Newman+htmlextra).

7. CI/CD (GitHub Actions + Newman)

Workflow .github/workflows/api-tests.yml : checkout → Node 20 → cài SUT → node server.js + wait-on → Newman (htmlextra) → upload artifact. Chi tiết + ý nghĩa: docs/ci-cd-report.md .

Run	Suite	Kết quả	Link
A — all-pass	green (10 case PASS-expected)	✅ xanh	https://github.com/trngnneee/eshop-sut/actions/runs/32619544526
B — one-fail	onefail (green + BUG-05)	❌ đỏ đúng 1 fail	https://github.com/trngnneee/eshop-sut/actions/runs/32619881963

Full collection (276 fail chủ đích) không dùng làm gate; CI tách 2 suite gọn, tắt định (verify local: green 10/0, onefail 11/1).

8. AI-driven Test Generator (Agent Skill · Bước 9)

`.agent/skills/api-fr-testing/` : SKILL.md + references/pseudocode.md + scripts/generator.py .
Input: `openapi.yaml` (+ requirements) → Output: `*.postman_collection.json` + bảng test case.
Diagram kiến trúc tự vẽ (`architecture.drawio` / `.png`) — pipeline generate → contract-parse → technique-expand → assertion-map → emit.

Video demo Agent Skill: <https://drive.google.com/drive/folders/13ISkQF2vfeJV9PTGLdRy5Aptm-ZgceKb?usp=sharing> (bản trong repo: `demo-video/`).

9. Sử dụng AI & minh bạch

- AI làm: plan, OpenAPI, 5 JSON Schema, sinh 219 test case, dựng collection/env/CSV/teardown/mock, draft 20 bug report, workflow CI.
- Tôi làm/quyết: scope + kỹ thuật, **toàn bộ expected oracle** (theo contract), DEC-01 (STRICT id), **chạy SUT + cURL xác nhận mọi actual**, forge JWT, sửa 5 mismatch OpenAPI, diagram tự vẽ, audit + critique.
- Chi tiết log verbatim: `ai_declaration/[AI-02]` AI Audit Report . Phản tỉnh: `docs/ai-critique.md` . Khai báo: `[AI-03]` , checklist riêng tư: `[AI-05]` .
- 20/20 bug do tôi phát hiện/xác nhận bằng execution**, không do AI suy từ spec — đúng ranh giới "con người sở hữu oracle, AI sở hữu enumeration".

Phụ lục — Chỉ mục artifact

`README.md` (self-assessment) · `openapi.yaml` · `testcases/` (12 file + summary) · `postman/` (collection + CI + schemas + data + features) · `newman/` (3 report + screenshots) · `bug-reports/` (20 + README) · `docs/` (report, ai-critique, ci-cd-report, audit, extended, openapi-audit) · `ai_declaration/` (AI-02/03/05) · `.agent/skills/api-fr-testing/` · `.github/workflows/api-tests.yml` .